LEVEL 11 · PART V

Security / DevSecOps

11

Goal: Build security into every stage: servers, cloud, containers, code and pipelines.

RECOMMENDED TIME
3-4 weeks

TOPICS
13

PRACTICE / CAPSTONE
Harden the sample stack end to end and add Trivy, dependency, secrets and ZAP scans to the CI pipeline.

Topics

#	Topic	What you will learn
1	Linux Security and SSH Hardening **p.2125**	disable root/password SSH, fail2ban, ufw, unattended-upgrades, auditing
2	Least-privilege IAM **p.2137**	scoping policies, permission boundaries, Access Analyzer, role assumption
3	Cloud Security Groups and Policies **p.2151**	network exposure, bucket policies, SCPs, CSPM
4	Secrets Management and Encryption **p.2165**	Vault/Secrets Manager, encryption at rest/in transit, envelope encryption, rotation
5	OWASP Top 10 **p.2177**	each category with a vulnerable code example and the fix
6	Authentication and Authorization **p.2191**	authn vs authz, sessions, RBAC/ABAC, MFA
7	JWT and OAuth **p.2203**	OAuth2 flows, OIDC, JWT structure, pitfalls (alg none, no revocation)
8	API Security **p.2217**	rate limits, input validation, authN/Z on every route, API gateway, OWASP API Top 10
9	Container Image Scanning (Trivy) **p.2231**	scanning images, severity gates in CI, SBOMs
10	Dependency Scanning (Snyk, Dependabot) **p.2245**	SCA, lockfiles, automated update PRs, supply-chain attacks

#	Topic	What you will learn
11	Secrets Scanning **p.2257**	gitleaks/trufflehog/GitHub push protection, what to do when a secret leaks
12	Rootless and Minimal Containers **p.2271**	rootless Docker/Podman, distroless, seccomp, capabilities
13	Dynamic Testing with OWASP ZAP **p.2285**	baseline scan, DAST vs SAST, running in CI against staging
★	Level capstone project **p.2299**	Harden the sample stack end to end and add Trivy, dependency, secrets and ZAP scans to the CI pipeline.

How to work through this level

1. Read each topic in order: *what it is* → *why it matters* → *real-world example* → *diagram* → *guide*.
2. Do **every task** in the topic's *Tasks* section and tick the box (`- [x]`) in your own fork or notes.
3. Answer the *Self-check questions* without looking, then reveal the answers.
4. Finish with the **capstone project**, which combines all topics of the level.
5. Move on only when you can do the capstone's *Prove it* task without the guide.

Topic flow

